

acme/widget-api

Registry harbor.example.mil · Report SR-2026-0042 · Issued 2026-06-28

Critical + High findings: **2** · Unfixed Critical/High: **1** · Scanned **2026-06-28** · Trivy 0.52.0 · DB ver 2, updated 2026-06-28 06:14 UTC

This report records the scan results for the immutable digests in §1. Any rebuild produces a new digest and requires a new report. Informational only — it is not an approval or authorization to operate.

1. Images Covered

This report describes *only* the exact images below, identified by immutable SHA256 digest. Tags are mutable and are listed for convenience only — the digest is the binding identifier.

Variant	Tag	Image @ Digest	Size
full	1.8.3	harbor.example.mil/acme/widget-api@sha256:3f1d9c0a8b7e6f5d4c3b2a1908f7e6d5c4b3a29180f7e6d5c4b3a29180f7e6d5	82 MB
airmark	1.8.3-airmark	harbor.example.mil/acme/widget-api@sha256:a1b2c3d4e5f6079889aabbccddeeff00112233445566778899aabbccddeeff00	31 MB

full — complete runtime image. **airmark** — minimized/distroless variant for air-gapped & edge deployment. Each variant carries its own digest; both are covered by this single report.

2. Harbor Vulnerability Scan Results

CRITICAL 0HIGH 2MEDIUM 4LOW 9UNKNOWN 1TOTAL 16

Full enumeration of all Critical and High findings (the gate-relevant set):

CVE	Severity	Component @ Version	Fixed Version
CVE-2024-45491	HIGH	libexpat 2.5.0-1	2.6.3-1
CVE-2024-6119	HIGH	openssl 3.0.13-1	3.0.14-1

Severity as adjudicated by Harbor (Trivy). Only Critical/High shown; the full Medium/Low set is in the attached SBOM-linked scan JSON (§7).

3. Vendor Statement & VEX — Unfixed Critical / High

For every Critical/High finding *without an applied fix*, the statement below is the vendor’s position. These rows can be transcribed directly into a POA&M. Justifications use OpenVEX status vocabulary.

CVE-2024-45491

NOT_AFFECTED

full

VEX justificationStatementvulnerable_code_not_in_execute_path
libexpat is present only as a transitive dependency of the man-page tooling, which is stripped at runtime. No code path in widget-api invokes the affected XML_ParseBuffer overflow. A fix (2.6.3-1) will still be absorbed on the next monthly base rebase.

Remediation by2026-07-31

4. Software Bill of Materials (SBOM)

Format	CycloneDX (1.6 JSON)
Components inventoried	214 components (118 OS pkgs, 96 application)
Attached as	in-toto attestation (predicate cyclonedx)
SBOM digest	sha256:9988776655443322110099887766554433221100998877665544332211009988

The SBOM is machine-readable and answers component-presence questions (e.g. “is log4j-core or openssl X present?”) without re-scanning. It is attached to the image as an in-toto attestation and independently retrievable from the registry.

5. Build Provenance & Signature

Built by	GitHub Actions (hosted runner, OIDC)
Workflow	.github/workflows/release.yml@refs/tags/v1.8.3
Source	acme/widget-api @ c0ffee1
Run	actions/runs/9876543210 · SLSA Provenance v1
Signed with	cosign (keyless / GitHub OIDC, repo=acme/widget-api)
Transparency log	https://rekor.sigstore.dev (index 148820391)

```
cosign verify \  
--certificate-identity-regexp '^https://github.com/acme/widget-api' \  
--certificate-oidc-issuer https://token.actions.githubusercontent.com \  
harbor.example.mil/acme/widget-api@sha256:3f1d9c0a...e6d5
```

Verifying the signature against the digest in §1 proves the scanned image is the one this pipeline built — not a substitute.

6. Image Hardening

- ✓ Runs as non-root (UID 65532, no setuid binaries)

✓ Chainguard (Wolfi) distroless base, daily-rebuilt

✓ Minimal attack surface — airmark variant is 31 MB
- ✓ No shell and no package manager in the image

✓ Read-only root filesystem compatible

✓ No secrets or build tooling in final layers

7. Scan Metadata — As Of

Scan date	2026-06-28	Trivy vuln DB	ver 2, updated 2026-06-28 06:14 UTC
Harbor	Harbor v2.11.1	Report prepared by	J. Rivera, Product Security Lead, ACME Platform
Scanner	Trivy 0.52.0	Contact	security@acme.example

A vulnerability scan is a point-in-time assertion. This report reflects the threat data available as of 2026-06-28 and is valid only for the digests in §1.